ActivityRoster: user-experience review, security audit and copy fact-check, 23 October 2026

Scope: the public site (activityroster.com), the office platform, the instructor app, with extra weight on sign-up and onboarding. No product changes were made for this report. Everything below is a recommendation for Conor to pick from.

Headline

User experience: 7.2 / 10. The platform is deep and coherent once a centre is set up, and the instructor app is simple. The weak point is the path from "visitor" to "first roster built": the sign-up form asks for seven things plus a tick and a bot check before the button works, it sits at the bottom of an 8,300-pixel home page, the owner cannot get in until they click an email link and then choose a PIN, and the wizard opens by saying "allow 20 to 30 minutes". Each of those is a place to lose a busy centre manager. The 50 recommendations are ranked with that path first.

Security: 8.6 / 10. No new medium or high finding in the application code. One dependency matter needs action: the installed Next.js (16.3.8) carries a published denial-of-service advisory that applies to this app, and two remote-code advisories that do not apply as deployed. Upgrade to 16.4.1 through staging. The sign-in relaxations made on 17 October are a deliberate trade and are sound for centres, but they also apply to the platform owner's own Dev Center login, which should keep the stricter check.

Copy: mostly accurate; 11 statements need changing. Four pieces of sign-in wording describe the old behaviour, the trust page describes the old behaviour and overstates where the application runs, the competitor price table has no "checked on" date and one figure looks high, and the app section says the app is on the App Store before it is.

1. How this was done, and its limits

- **Browsed, not just read.** The site, office and app were run locally from the current code with the made-up demo centre (Lakeside Sailing Centre) and a brand-new centre (Harbour Watersports) for the setup wizard. 33 public pages were crawled at desktop and phone widths, checking status, title, description, heading, console errors, sideways scrolling and small tap targets. The office was walked through signed in as the owner (20 pages), the wizard was clicked through all seven steps, the app sign-up screens were viewed on a phone-sized screen, and the instructor portal was walked through signed in as an instructor (9 pages). 120 screenshots were taken and reviewed.
- **Code read behind every flow:** sign-up route and provisioning, the sign-in, device and PIN gates, the wizard, the office and portal pages, every API route's guard, every "use server" action file touched since the last audit, the webhooks, uploads, imports, exports, headers and cookies.

- **Security re-check** against the 14 October audit's findings, the OWASP top ten classes, `npm audit`, and the published advisories for the exact Next.js version installed.
- **Fact-check** of the home page, pricing, trust, privacy, sign-in, app and Learning Centre wording against the code and, for competitor prices and RYA ratios, against public sources.
- **Limits.** Local timings are development-mode and were not scored. The office was not tested at phone width (recommendation 40). The 100 blog articles live in the database and were sampled, not read in full. Companies House could not be reached from this environment, so the company number was not verified. No penetration test by a second firm.

2. User experience: what was found

2.1 The path from visitor to first roster

Counted from the home page, a new centre manager today goes through:

Step	What they do	Friction found
1	Click "Start my free month" in the hero	Jumps to a form at the bottom of a 1,700-word page
2	Fill the form	Email, password (with strength meter), centre name, web address, jurisdiction, kind of centre, terms tick, Turnstile. The button is disabled until the tick
3	Wait for provisioning	A progress bar; fine
4	Open their email and click the confirmation link	Sign-in is refused until this is done (`requireEmailVerification`). Delayed or spam-filtered mail stops everything
5	Choose a 4-digit PIN	A second screen before anything is seen
6	The wizard: "Allow 20 to 30 minutes", 7 steps marked essential	Step 2 shows all 57 RYA course types as chips to tick; step 3 wants each instructor typed with their instructor types; steps 4 to 6 (invite, onboarding tracker, roster PDF) are not needed for a first roster
7	The dashboard	A trial banner "16 days left, add payment" on every page from day one

Nothing here is broken. It is simply more than it needs to be before the person has seen a roster.

2.2 The public site

- The home page is long (8,300 px, 1,700 words) and repeats the primary call to action five times above the fold on a phone (Try free, Try free, Sign in, Sign in, Start my free month, plus Demo).
- The cookie bar appears on every page although the site sets only strictly necessary cookies. Under UK PECR no consent is needed for those, so the bar is pure friction, and on phones it covers the bottom of the screen.
- "Sign in" in the header leads to a chooser page (Centre admin or Instructor portal) before the sign-in form, although the form already works out where to send someone from their email.

- The pricing page is clear and the plan cards line up. The comparison table quotes four competitors' per-user prices with no date and no links.
- The demo page opens with a paragraph of text and a wall of chips; the explainer video and first screenshot are below.
- Footer and chip links are small on phones (29 to 35 targets under 32 px on the pricing, contact and login pages).
- Date inputs render as mm/dd/yyyy in Chrome regardless of locale (leave, documents, settings).

2.3 The office

- The sidebar's numbered groups (1 Set up, 2 Roster, 3 Pay & extras) are a strength. Seventeen items are always shown even when the wizard switched the extras off.
- Settings is one very long page (778 form fields, the slowest page to render). Course setup is the densest (290 fields, 176 small targets).
- The Instructors list is rich but busy: each row carries "Portal access", "Re-send invite" and now "Phone alerts off".
- The dashboard on a quiet day is a grid of zeros under "Nothing on the water today".
- The roster week with its "Confirm the roster" strip, the per-day traffic lights and "Every place filled · 4 problems" is the best screen in the product. Keep it exactly as it is.

2.4 The instructor app

- Sign-up is five fields including "Confirm password", then a 6-digit code, then a PIN, then the join screen: four screens before the schedule.
- The sign-in screen still says "You'll need your centre's company code".
- Hours is a long list of identical "Half-term Camp: Stage 1 · Pending" rows.
- Settings still says "Join another centre with a code".
- The schedule, availability grid, documents and the welcome checklist are clear and quick.

3. The 50 recommendations

Ranked by effect on sign-ups and first use, then on daily use. Effort: S (hours), M (a day or two), L (several days).

Sign-up and onboarding (1 to 15)

1. **Email first, everything else second (M).** Make step one a single email box (plus Turnstile) that creates the lead the moment it is submitted. Step two asks for password and centre name only. Today a visitor who abandons the seven-field form leaves nothing behind.
2. **Put the email box in the hero (S).** The hero button currently jumps 7,000 px down the page to the form. Put the email field beside the headline and give the full form its own address, `/start`, so ads, emails and the pricing cards can link to it directly.
3. **Drop the terms tickbox (S).** Replace it with "By continuing you agree to the Terms and Privacy Policy" under the button, and enable the button from the start. This is the standard

pattern and is valid for a business sign-up.

4. **Let the owner in straight away (M).** Create the session at sign-up and take them to the office immediately; keep "Confirm your email" as a banner they must clear within 7 days. Today sign-in is refused until the link in the email is clicked, which is the single most common place SaaS trials die.
5. **Move the PIN out of the first visit (S).** Ask for the PIN at the end of the wizard or on the second visit, not as a wall before the first screen.
6. **Make the web address automatic (S).** Derive it from the centre name, show it in step two as "yourclub.activityroster.com (change)", and allow one change in Settings within 30 days instead of "it can't be changed later".
7. **Move jurisdiction and kind of centre into the wizard (S).** Default to England and RYA centre; ask on wizard step 1 where the choice is explained.
8. **Cut the wizard's essential path to three steps (M).** How you run, Courses, Team. Make Invite, Onboarding tracker and Roster PDF optional cards on the dashboard. Replace "Allow 20 to 30 minutes" with "About 5 minutes to your first week".
9. **Pre-select the common courses (S).** On the courses step, show the eight most common RYA courses ticked with "Show all 57". Most centres run a handful.
10. **Offer an example week (M).** A "Load an example week" button in the wizard puts six made-up instructors and a week of sessions on the roster so the first thing they see is a working roster, with a one-click "Clear the example".
11. **Hide the trial banner until it matters (S).** Show "16 days left" only from day 23, or once the first roster is built. From day one it reads as a demand for payment before any value is seen.
12. **A short welcome email series (M).** Day 0: the three steps and the guide. Day 2: import your courses. Day 7: invite your team. Day 25: your trial ends on … The trial-end survey already exists; the lead-in does not.
13. **Dashboard "next best action" (S).** After the wizard, the dashboard's zero tiles should give way to one card: "Add your first course" or "Invite your instructors", and the checklist should be the top of the page until done.
14. **Keep "Skip for now" honest (S).** The wizard's skip returns to the dashboard checklist (good); add a one-line "Finish setting up (3 steps left)" bar at the top of every office page until it is done.
15. **Count the funnel (M).** There is no product analytics, by design. Add privacy-safe server-side counters in the Dev Center: sign-ups started, completed, email confirmed, wizard step reached, first roster built, first invite sent. Without these, none of the above can be measured.

The public site (16 to 29)

16. **Shorten the home page (M).** Keep the hero, "your week in three steps", the platform grid, pricing teaser, one proof block and the FAQ; move the discipline gallery, "built for the way RYA centres work" and the second photo bands to a /features page.
17. **One primary button above the fold (S).** "Start my free month" once, "See the demo" once. Drop the duplicated Try free / Sign in pairs on phones.

18. **Remove the cookie bar (S).** Replace it with a footer line "Only the cookies needed to sign you in; no tracking" linking to /cookies. Nothing is lost and every page gets its bottom back on phones.
19. **Send "Sign in" straight to the form (S).** Retire the admin/instructor chooser; the sign-in page already routes by membership and offers "Sign in to my portal" if needed.
20. **Fix the sign-in wording (S).** "We'll then email you a code to confirm it's you" is no longer true; it only happens somewhere new.
21. **Demo page: show before telling (S).** Explainer video and the first screenshot at the top, the chip index below, and a "Start my free month" at the end of each section.
22. **Pricing table: date it and link it (S).** Add "Prices checked on <date>" and a link to each provider's pricing page; soften "cheaper at every size" to "cheaper once you count everyone you roster" (see fact-check: RotaCloud's base plan is nearer £2 per user, so at 10 people it is cheaper than Small Club).
23. **Pricing cards should go to /start with the plan preselected (S)**, not back to the bottom of the home page.
24. **One name for the guides (S).** The header says "Learn", the footer and pages say "Learning Centre". Pick one.
25. **Bigger tap targets in footers and chip rows (S).** 29 to 35 targets per page are under 32 px on phones.
26. **Short capture on the ten SEO landing pages (S).** Same email-first box as recommendation 1 instead of the full form.
27. **Add proof (M).** No named centre, quote or logo appears anywhere. Two pilot quotes, or "in pilot with N centres", lifts conversion more than any copy change.
28. **Dates in British format (S).** Give date inputs a dd/mm/yyyy pattern or a small picker; Chrome shows mm/dd/yyyy.
29. **Trim page titles (S).** /guides' title is 68 characters and truncates in Google.

The office (30 to 40)

30. **Split Settings (M).** Five tabs already exist in the copy; make each tab its own page with an index on the left and a "find a setting" box. It is the slowest page and the hardest to scan.
31. **Collapse Course setup (M).** Show the instructor-type grid per course on demand rather than every row at once; it is the densest page in the product.
32. **One status column on the Instructors list (S).** Fold "Portal access", "Re-send invite" and "Phone alerts off" into a single status chip with a menu.
33. **A quieter dashboard on quiet days (S).** Hide zero tiles under one "All quiet today" line and show the week ahead instead.
34. **Hide the extras the centre switched off (S).** When the wizard leaves Equipment, Locations, Time clock, Payroll or Recruit off, drop them from the sidebar until switched on in Settings.
35. **Courses page: form on demand (S).** The "Add a course" form is always open above the list; make it a button that opens a drawer, so the calendar and the list get the space.
36. **Copy-invite-link on the Instructors page (S).** The wizard writes a WhatsApp-ready message; put the same "Copy message" button next to "Invite".

37. **Plain-English tooltips on jargon (S).** "Instructor type", "place", "ratio", "Senior Instructor cover" each get a small "?" with one sentence, for the admin who is not an RYA instructor.
38. **Keep the roster week exactly as it is.** It is the best screen. Only addition: a keyboard shortcut list for power users.
39. **Default "stay signed in" (S).** The office sign-in asks "Stay signed in?" with two buttons every time; default to yes with a "just this once" link.
40. **Test the office on a phone (M, verify first).** Owners check tomorrow's roster from a phone. The office is desktop-first with a sidebar; this review did not test it at phone width, so check the dashboard, roster week and confirm-day flow at 390 px and fix what breaks.

The instructor app (41 to 50)

41. **Four fields, not five (S).** Drop "Confirm password" in favour of a show/hide toggle. Keep name, email, password, optional mobile.
42. **Fix the sign-in wording (S).** "You'll need your centre's company code — ask your admin" should read "If your centre has added you, it's offered by name; otherwise ask for their company code".
43. **Fold the PIN into the join screen (M).** Code, then one screen that sets the PIN and joins the centre, then the schedule: three screens instead of four.
44. **Group the Hours list (S).** Group by course and day with a subtotal, and show "Pending" once per day rather than on every row.
45. **Leave presets (S).** "Tomorrow", "This weekend", "Next week" buttons above the date fields; capitalise the leave type names.
46. **Settings wording (S).** "Join another centre with a code" becomes "Join another centre".
47. **Keep the notification push as built.** The daily sheet and bar are the right level of insistence; review the opt-in rate after a month.
48. **A "what's new" line (S).** When the web app changes behind the native shell, a one-line notice on first open stops "it looks different" messages.
49. **App Store and Play links on the site only once live (S).** The Learning Centre already says "on the App Store and Google Play"; hold that wording until both are approved, then add the badges to the invite email and the Instructors page.
50. **Measure app adoption in the office (S).** On the Instructors page header: "9 of 15 in the app · 6 with phone alerts". The data exists; show it once rather than per row.

4. Security audit

4.1 New findings

S1. Next.js 16.3.8 is inside three published advisories. Medium, act through staging. `npm audit` reports: a denial-of-service in App Router server actions (GHSA-p3m5-59mp-jv5r, affects 16.0.0 to 16.4.0; this app has 52 server-action files, so it applies: crafted requests can tie up the Worker's CPU); a remote-code advisory in the image optimiser's SVG handling (GHSA-2464-fhr4-w9xw; needs the `sharp` library on glibc Linux, which the Cloudflare Worker does not run, so not applicable as deployed); and a remote-code advisory in `use cache` functions returning typed arrays (GHSA-673q-mjm6-r5xr; the app has no `use cache`, so not applicable). All three

are fixed in 16.4.1. Upgrade `next` to 16.4.1 with the OpenNext adapter checked, run the suite, deploy to staging, then production. Also set `images: { unoptimized: true }` in `next.config.mjs`: the app does not use `next/image`, and `/_next/image` currently answers in development; removing the route removes the surface.

S2. The relaxed sign-in check also relaxes the Dev Center. Low, small change. On 17 October a new device in a known country (for office users, the same town) was made to pass silently with an email alert instead of a password or code. `requirePlatformAdmin` uses the same gate, so a new device in the owner's town now reaches the Dev Center without that step too. The Dev Center still requires the authenticator app and the PIN, so the practical exposure is small, but the highest-privilege login should keep the strict version: pass a flag so the platform-admin path always challenges a new device.

S3. The reviewer-login exemption. Low, by design. `APP_REVIEW_EMAILS` lets named logins through the "somewhere new" check only; password, email verification and PIN still apply, and the pass is logged as a security event. Keep it to a throw-away email, never a real owner's, and remove it after store approval.

S4. Clipboard reads on the code screens. Info. The app reads the clipboard when the person returns to a code screen and keeps only a 6-digit number; nothing else is read or stored, and iOS shows its own notice. Acceptable; documented here for the record.

S5. Join-by-name reveals which centres list a verified email. Info. A signed-in, verified user can learn that a centre has their own email on its instructor list. This is the person's own data and the intended behaviour.

S6. Boaty Jobs webhook. Info, solid. HMAC over the raw body in constant time, rate-limited, duplicate event ids dropped, every payload Zod-checked, and nothing happens at all until the partner secret is set. No timestamp window, which only matters for replay of an unseen id, which cannot be forged.

4.2 The 14 October findings, re-checked

Finding	Then	Now
S1 authenticator exemption by path	Fixed	Still fixed
S2 locked-trial allowance for actions	Fixed	Still fixed
S3 R2 writes for read-only centres	Fixed	Still fixed
S4 unscrubbed error reports	Fixed	Still fixed; sign-up failures now also land in the error log, scrubbed the same way
S5 workflow token permissions	Fixed	Still fixed (new iOS and Android workflows declare `contents: read`)
S6 actions pinned by tag	Open	**Open.** 39 `uses:` lines still follow moving tags
S7 scheduled jobs run from `main`	Open	**Open.** `main` last moved on 15 October; the DNS export has still not been run by hand
S8 dependency advisories (tooling)	Open	**Open and now 17** (1 critical, 10 high, 6 moderate). The critical one is `next` (S1 above); the rest are `tailwindcss`, `vite`, `wrangler` build chains that never ship in the Worker

Finding	Then	Now
S9 onboarding cookie flags	Fixed	Still fixed
S10 foreign document key	Fixed	Still fixed
S11 public-site CSP `unsafe-inline`	Accepted	Unchanged; signed-in pages keep the nonce policy
S12 email-exists at sign-up	Accepted	Unchanged
S13 X-Frame-Options SAMEORIGIN beside frame-ancestors none	Accepted	Unchanged

4.3 What is solid (verified this time)

- **Every API route is guarded or deliberately public.** 44 routes read: platform-admin routes behind `requirePlatformAdmin`, office routes behind `requireTenant`, machine endpoints (mail drain, outreach tick, inbound receipts, backup reports) behind the cron secret, Stripe and Resend webhooks signature-checked, the Boaty webhook as above. The only unguarded routes are health, version, the public video files (allow-listed names) and blog images (path-traversal checked).
- **Sign-up is now all-or-nothing.** A failure part-way removes the centre, its seeded rows and the login, records the reason in the Dev Center error log, and the person can try again. Four tests cover it.
- **Tenant isolation test green** with the two new tables (job posts, job syncs) included; 706 tests pass.
- **Auth:** email verification required, 8-character minimum with breached-password check, rate limits per IP and per email that fail closed, cross-subdomain cookies `Secure` / `HttpOnly` / `SameSite=Lax`, trusted origins limited to the apex and its subdomains, PIN lockout, "sign out all devices".
- **Inputs:** Zod on every action and route checked; uploads capped at 10 MB with content sniffing; imports capped per run; CSV cells escaped against formula injection; `next` parameters validated to same-site paths in every place they are read.
- **Headers:** HSTS with preload, nosniff, frame-ancestors none, referrer and permissions policies, strict CSP with nonces on signed-in pages; `unsafe-eval` appears only in development.
- **Data:** D1 and R2 pinned to Western Europe, append-only audit and security logs, Sentry with email scrubbing, nightly encrypted backup, monthly restore rehearsal.

5. Fact-check of the site copy

Where	Statement	Verdict	Fix
/sign-in	"We'll then email you a code to confirm it's you"	**Out of date** since 17 Oct: only somewhere new	Reword
/app sign-in	"You'll need your centre's company code — ask your admin"	**Out of date**: offered by name when added	Reword

Where	Statement	Verdict	Fix
App settings	"Join another centre with a code"	**Out of date**	Reword
/trust	"confirm a code … the first time on a device and after 12 hours away" and "New devices and countries trigger an extra check"	**Out of date**	Reword to "somewhere new"; new devices get an email
/trust	"Everything is hosted on Cloudflare in Western Europe: the database, uploaded documents and the application itself"	**Overstated**: data stores are pinned to Western Europe; the application runs on Cloudflare's network wherever the visitor is	"Your data is stored in Western Europe; the application runs on Cloudflare's network"
/trust	"Last reviewed 4 October 2026"	Stale once the above changes	Update the date
Learning Centre, app section	"ActivityRoster on the App Store and Google Play"	**Premature**: not yet approved on the App Store	Hold until live
/pricing	Competitor prices £4.50, £4.00, £3.80, £4.20 per user	**Unverifiable and undated.** Public sources: Deputy about $5 to $9, When I Work $2.50 to $8, Planday €2.49 to €6.49, RotaCloud's base plan nearer £2 per user. The figures sit inside those ranges except RotaCloud, which looks high for the base plan	Add "checked on" and links; soften "at every size"
/pricing	£35 / £385 a year, 1 month free; £65 / £650 a year, 2 months free	**Correct** (420 − 385 = 35; 780 − 650 = 130)	None
Home	"Free for a month · no card · set up in an afternoon · from £35/month"	Correct against pricing config and the wizard	None
Home	"EU-hosted · Cloudflare · UK GDPR-ready", "Fully isolated"	Correct for data storage; isolation enforced and tested	None
Home	"Clash detection: double-booked instructor or boat"	Correct: tracked equipment is conflict-checked	None
Home platform grid	Roster builder, Auto-roster, app, certs and vetting, hours beside names, access per admin, printable PDF, emergency sheet, leave and cover, payroll export, import, audit trail and GDPR tools	All present in the code	None
Landing pages	"Drag-and-drop roster board"	Correct (RosterBoard supports drag)	None
Guides	Ratios 1:6 dinghy, 1:3 powerboat, 1:4 keelboat with instructor aboard	Consistent with published centre operating procedures; the RYA's own document could not be fetched	Cite "RYA guidance, check your recognition"
Home FAQ	Jurisdictions, data location, under-18 privacy, import, app or browser	All correct against the code	None
Footer	"ActivityRoster Ltd, company number 17505500, 71-75 Shelton Street"	**Not verified** (Companies House unreachable from here)	Confirm once on Companies House

Where	Statement	Verdict	Fix
/privacy	Updated 17 October 2026; lists Cloudflare, Stripe, Resend, Sentry, Firebase and Apple, Boaty Jobs	Matches the sub-processor list	None
Blog (100 articles, sampled)	General guidance on volunteers, GDPR and safety	Advisory in tone, no specific legal figures found in the sample	Full read when time allows

6. What to do first

1. Upgrade Next.js to 16.4.1 through staging (S1) and keep the strict device check for the Dev Center (S2). Half a day.
2. Fix the eleven wording items in section 5. An hour.
3. Recommendations 1 to 5: email-first sign-up on a `/start` page in the hero, no tick box, straight into the office, PIN later. Two to three days, and the biggest lift to trials.
4. Recommendations 8 to 11: the three-step wizard, example week and the quieter trial banner. Two days.
5. Recommendation 15: the funnel counters, so the next review can say what changed.